



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Site: <http://127.0.0.1:8000>

Generated on Sun, 5 Jul 2026 04:00:27

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	2
Medium	0
Low	2
Informational	5

Alerts

Name	Risk Level	Number of Instances
SQL Injection	High	7
SQL Injection - MySQL (Time Based)	High	1
Big Redirect Detected (Potential Sensitive Information Leak)	Low	12
X-Content-Type-Options Header Missing	Low	3
Authentication Request Identified	Informational	3
Information Disclosure - Suspicious Comments	Informational	2
Modern Web Application	Informational	1
Session Management Response Identified	Informational	28
User Controllable HTML Element Attribute (Potential XSS)	Informational	4

Alert Detail

High	SQL Injection
Description	SQL injection may be possible.
URL	http://127.0.0.1:8000/login
Node Name	http://127.0.0.1:8000/login ()(_token,email,password)
Method	POST

Attack	password" OR "1"="1" --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [password" AND "1"="1" --] and [password" OR "1"="1" --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)
Method	POST
Attack	27-2
Evidence	
Other Info	The original page results were successfully replicated using the expression [27-2] as the parameter value The parameter value being modified was stripped from the HTML output for the purposes of the comparison.
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)
Method	POST
Attack	Sangat Setuju OR 1=1 --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [Sangat Setuju AND 1=1 --] and [Sangat Setuju OR 1=1 --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)
Method	POST
Attack	8 ASC --
Evidence	
Other Info	The original page results were successfully replicated using the "ORDER BY" expression [8 ASC --] as the parameter value The parameter value being modified was stripped from the HTML output for the purposes of the comparison.
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)

Method	POST
Attack	SMA' OR '1'='1' --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [SMA' AND '1'='1' --] and [SMA' OR '1'='1' --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)
Method	POST
Attack	L" OR "1"="1" --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [L" AND "1"="1" --] and [L" OR "1"="1" --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)
Method	POST
Attack	tes' AND '1'='1
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [tes' AND '1'='1] and [tes' AND '1'='2] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was returned for the original parameter. The vulnerability was detected by successfully restricting the data originally returned, by manipulating the parameter.
Instances	7
	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them.

Solution	Do <i>*not*</i> concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
CWE Id	89
WASC Id	19
Plugin Id	40018

High	SQL Injection - MsSQL (Time Based)
Description	SQL injection may be possible.
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)
Method	POST
Attack	tes WAITFOR DELAY '0:0:15' --
Evidence	
Other Info	The query time is controllable using parameter value [tes WAITFOR DELAY '0:0:15' --], which caused the request to take [17,327] milliseconds, when the original unmodified query with value [tes] took [0] milliseconds.
Instances	1
Solution	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do <i>*not*</i> concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible.

	In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.
	Grant the minimum database access that is necessary for the application.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
CWE Id	89
WASC Id	19
Plugin Id	40027

Low	Big Redirect Detected (Potential Sensitive Information Leak)
Description	The server has responded with a redirect that seems to provide a large response. This may indicate that although the server sent a redirect it also responded with body content (which may include sensitive details, PII, etc.).
URL	http://127.0.0.1:8000/petugas/kelola-survei
Node Name	http://127.0.0.1:8000/petugas/kelola-survei
Method	GET
Attack	
Evidence	
Other Info	Location header URI length: 27 [http://127.0.0.1:8000/login]. Predicted response size: 327. Response Body Length: 354.
URL	http://127.0.0.1:8000/petugas/manajemen-admin
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin
Method	GET
Attack	
Evidence	
Other Info	Location header URI length: 27 [http://127.0.0.1:8000/login]. Predicted response size: 327. Response Body Length: 354.
URL	http://127.0.0.1:8000/petugas/survei/15
Node Name	http://127.0.0.1:8000/petugas/survei/15
Method	GET
Attack	
Evidence	
Other Info	Location header URI length: 27 [http://127.0.0.1:8000/login]. Predicted response size: 327. Response Body Length: 354.
URL	http://127.0.0.1:8000/login
Node Name	http://127.0.0.1:8000/login ()(_token,email,password)
Method	POST

Attack	
Evidence	
Other Info	Location header URI length: 27 [http://127.0.0.1:8000/login]. Predicted response size: 327. Response Body Length: 354.
URL	http://127.0.0.1:8000/logout
Node Name	http://127.0.0.1:8000/logout ()(_token)
Method	POST
Attack	
Evidence	
Other Info	Location header URI length: 27 [http://127.0.0.1:8000/login]. Predicted response size: 327. Response Body Length: 354.
URL	http://127.0.0.1:8000/petugas/manajemen-admin
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin ()(_token,email,full_name,password,password_confirmation)
Method	POST
Attack	
Evidence	
Other Info	Location header URI length: 45 [http://127.0.0.1:8000/petugas/manajemen-admin]. Predicted response size: 345. Response Body Length: 426.
URL	http://127.0.0.1:8000/petugas/manajemen-admin/16
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin/16 ()(_method,_token)
Method	POST
Attack	
Evidence	
Other Info	Location header URI length: 45 [http://127.0.0.1:8000/petugas/manajemen-admin]. Predicted response size: 345. Response Body Length: 426.
URL	http://127.0.0.1:8000/petugas/manajemen-admin/16
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin/16 ()(_method,_token,admin_id,email,full_name,password,password_confirmation)
Method	POST
Attack	
Evidence	
Other Info	Location header URI length: 45 [http://127.0.0.1:8000/petugas/manajemen-admin]. Predicted response size: 345. Response Body Length: 426.

URL	http://127.0.0.1:8000/petugas/survei
Node Name	http://127.0.0.1:8000/petugas/survei ()(_token,description,end_date,questions[0][is_required],questions[0][is_required],questions[0][question_text],questions[0][question_type],questions[0][scale_max],questions[0][scale_max_label],questions[0][scale_min],questions[0][scale_min_label],questions[1][is_required],questions[1][options][],questions[1][options][],questions[1][question_text],questions[1][question_type],questions[1][scale_max],questions[1][scale_max_label],questions[1][scale_min],questions[1][scale_min_label],questions[2][is_required],questions[2][is_required],questions[2][question_text],questions[2][question_type],questions[2][scale_max],questions[2][scale_max_label],questions[2][scale_min],questions[2][scale_min_label],start_date,status,title)
Method	POST
Attack	
Evidence	
Other Info	Location header URI length: 43 [http://127.0.0.1:8000/petugas/kelola-survei]. Predicted response size: 343. Response Body Length: 418.
URL	http://127.0.0.1:8000/petugas/survei/11
Node Name	http://127.0.0.1:8000/petugas/survei/11 ()(_method,_token)
Method	POST
Attack	
Evidence	
Other Info	Location header URI length: 43 [http://127.0.0.1:8000/petugas/kelola-survei]. Predicted response size: 343. Response Body Length: 418.
URL	http://127.0.0.1:8000/petugas/survei/14
Node Name	http://127.0.0.1:8000/petugas/survei/14 ()(_method,_token,description,end_date,questions[0][id],questions[0][is_required],questions[0][is_required],questions[0][options][],questions[0][options][],questions[0][options][],questions[0][question_text],questions[0][question_type],questions[0][scale_max],questions[0][scale_max_label],questions[0][scale_min],questions[0][scale_min_label],start_date,status,title)
Method	POST
Attack	
Evidence	
Other Info	Location header URI length: 39 [http://127.0.0.1:8000/petugas/survei/14]. Predicted response size: 339. Response Body Length: 402.
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)
Method	POST
Attack	
Evidence	
Other	Location header URI length: 31 [http://127.0.0.1:8000/survei/15]. Predicted response size: 331.

Info	Response Body Length: 370.
Instances	12
Solution	Ensure that no sensitive information is leaked via redirect responses. Redirect responses should have almost no content.
Reference	
CWE Id	201
WASC Id	13
Plugin Id	10044

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://127.0.0.1:8000/build/assets/app-5Rzwb1sH.css
Node Name	http://127.0.0.1:8000/build/assets/app-5Rzwb1sH.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8000/build/assets/app-CAiCLEjY.js
Node Name	http://127.0.0.1:8000/build/assets/app-CAiCLEjY.js
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8000/build/assets/app-DXXI5aao.css
Node Name	http://127.0.0.1:8000/build/assets/app-DXXI5aao.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	3

Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://127.0.0.1:8000/petugas/manajemen-admin
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin ()(_token,email,full_name,password,password_confirmation)
Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=tes1234567@batam.go.id passwordParam=password referer=http://127.0.0.1:8000/petugas/manajemen-admin?search=&sort=name_asc csrfToken=_token
URL	http://127.0.0.1:8000/petugas/manajemen-admin/16
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin/16 ()(_method,_token,admin_id,email,full_name,password,password_confirmation)
Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=tes1234567@batam.go.id passwordParam=password referer=http://127.0.0.1:8000/petugas/manajemen-admin csrfToken=_token
URL	http://127.0.0.1:8000/login
Node Name	http://127.0.0.1:8000/login ()(_token,email,password)
Method	POST
Attack	
Evidence	password

Other Info	userParam=email userValue=admin@batam.go.id passwordParam=password referer=http://127.0.0.1:8000/login csrfToken=_token
Instances	3
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://127.0.0.1:8000/petugas/manajemen-admin
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin
Method	GET
Attack	
Evidence	<!-- Modal Edit Admin -->
Other Info	The following pattern was used: \bADMIN\b and was detected 11 times, the first in likely comment: "<!-- Modal Edit Admin -->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/petugas/manajemen-admin?search=tes+123&sort=newest
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin (search,sort)
Method	GET
Attack	
Evidence	<!-- Modal Edit Admin -->
Other Info	The following pattern was used: \bADMIN\b and was detected 2 times, the first in likely comment: "<!-- Modal Edit Admin -->", see evidence field for the suspicious comment /snippet.
Instances	2
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://127.0.0.1:8000/login
Node Name	http://127.0.0.1:8000/login

Method	GET
Attack	
Evidence	<script type="module" src="/build/assets/app-CAiCLEjY.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	1
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://127.0.0.1:8000/
Node Name	http://127.0.0.1:8000/
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/login
Node Name	http://127.0.0.1:8000/login
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/dashboard
Node Name	http://127.0.0.1:8000/petugas/dashboard
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/kelola-survei
Node Name	http://127.0.0.1:8000/petugas/kelola-survei

Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/kelola-survei?status=Semua+Status&search=survei
Node Name	http://127.0.0.1:8000/petugas/kelola-survei (search,status)
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/manajemen-admin
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/manajemen-admin?search=tes+123&sort=newest
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin (search,sort)
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/14
Node Name	http://127.0.0.1:8000/petugas/survei/14
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/14/edit
Node Name	http://127.0.0.1:8000/petugas/survei/14/edit
Method	GET
Attack	

Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/14/export-excel
Node Name	http://127.0.0.1:8000/petugas/survei/14/export-excel
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/14/export-pdf
Node Name	http://127.0.0.1:8000/petugas/survei/14/export-pdf
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/15
Node Name	http://127.0.0.1:8000/petugas/survei/15
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/15?page=1
Node Name	http://127.0.0.1:8000/petugas/survei/15 (page)
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/15/responden/32
Node Name	http://127.0.0.1:8000/petugas/survei/15/responden/32
Method	GET
Attack	
Evidence	sikap_session
Other	cookie:sikap_session

Info	cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/16
Node Name	http://127.0.0.1:8000/petugas/survei/16
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/create
Node Name	http://127.0.0.1:8000/petugas/survei/create
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/survei
Node Name	http://127.0.0.1:8000/survei
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/survei/15
Node Name	http://127.0.0.1:8000/survei/15
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/terima-kasih
Node Name	http://127.0.0.1:8000/terima-kasih
Method	GET
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/login

Node Name	http://127.0.0.1:8000/login ()(_token,email,password)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSUF-TOKEN
URL	http://127.0.0.1:8000/logout
Node Name	http://127.0.0.1:8000/logout ()(_token)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSUF-TOKEN
URL	http://127.0.0.1:8000/petugas/manajemen-admin
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin ()(_token,email,full_name,password,password_confirmation)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSUF-TOKEN
URL	http://127.0.0.1:8000/petugas/manajemen-admin/16
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin/16 ()(_method,_token)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSUF-TOKEN
URL	http://127.0.0.1:8000/petugas/manajemen-admin/16
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin/16 ()(_method,_token,admin_id,email,full_name,password,password_confirmation)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSUF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei
	http://127.0.0.1:8000/petugas/survei ()(_token,description,end_date,questions[0][is_required],questions[0][is_required],questions[0][question_text],questions[0][question_type],questions[0][scale_max],questions[0][scale_max_label],questions[0][scale_min],questions[0][scale_min_label],questions[1][is_required],questions[1][options][]],

Node Name	questions[1][options][],questions[1][question_text],questions[1][question_type],questions[1][scale_max],questions[1][scale_max_label],questions[1][scale_min],questions[1][scale_min_label],questions[2][is_required],questions[2][is_required],questions[2][question_text],questions[2][question_type],questions[2][scale_max],questions[2][scale_max_label],questions[2][scale_min],questions[2][scale_min_label],start_date,status,title)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/11
Node Name	http://127.0.0.1:8000/petugas/survei/11 ()(_method,_token)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/petugas/survei/14
Node Name	http://127.0.0.1:8000/petugas/survei/14 ()(_method,_token,description,end_date,questions[0][id],questions[0][is_required],questions[0][is_required],questions[0][options][],questions[0][options][],questions[0][options][],questions[0][question_text],questions[0][question_type],questions[0][scale_max],questions[0][scale_max_label],questions[0][scale_min],questions[0][scale_min_label],start_date,status,title)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8000/survei/15/submit
Node Name	http://127.0.0.1:8000/survei/15/submit ()(_token,age,answers[6],answers[7],answers[8],education,email,gender,name)
Method	POST
Attack	
Evidence	sikap_session
Other Info	cookie:sikap_session cookie:XSRF-TOKEN
Instances	28
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Controllable HTML Element Attribute (Potential XSS)
---------------	--

Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	http://127.0.0.1:8000/petugas/kelola-survei?status=Semua+Status&search=survei
Node Name	http://127.0.0.1:8000/petugas/kelola-survei (search,status)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://127.0.0.1:8000/petugas/kelola-survei?status=Semua+Status&search=survei appears to include user input in: a(n) [input] tag [value] attribute The user input found was: search=survei The user-controlled value was: survei
URL	http://127.0.0.1:8000/petugas/kelola-survei?status=Semua+Status&search=survei
Node Name	http://127.0.0.1:8000/petugas/kelola-survei (search,status)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://127.0.0.1:8000/petugas/kelola-survei?status=Semua+Status&search=survei appears to include user input in: a(n) [input] tag [value] attribute The user input found was: status=Semua Status The user-controlled value was: semua status
URL	http://127.0.0.1:8000/petugas/manajemen-admin?search=tes+123&sort=newest
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin (search,sort)
Method	GET
Attack	
Evidence	
	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL:

Other Info	http://127.0.0.1:8000/petugas/manajemen-admin?search=tes+123&sort=newest appears to include user input in: a(n) [input] tag [value] attribute The user input found was: search=tes 123 The user-controlled value was: tes 123
URL	http://127.0.0.1:8000/petugas/manajemen-admin?search=tes+123&sort=newest
Node Name	http://127.0.0.1:8000/petugas/manajemen-admin (search,sort)
Method	GET
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: http://127.0.0.1:8000/petugas/manajemen-admin?search=tes+123&sort=newest appears to include user input in: a(n) [button] tag [value] attribute The user input found was: sort=newest The user-controlled value was: newest
Instances	4
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031